

Vulnerability Assessment Report (VAR)

Cybersecurity Internship – Task 3

1. Executive Summary

This Vulnerability Assessment was conducted on the OWASP Juice Shop application running in a controlled lab environment using Kali Linux and Docker. The purpose of the assessment was to identify open ports, exposed services, misconfigurations, and possible security weaknesses without exploiting the vulnerabilities. The assessment was performed using industry-standard tools such as Nmap, Nikto, and Dirsearch. Multiple security issues and exposed endpoints were identified during the scanning process.

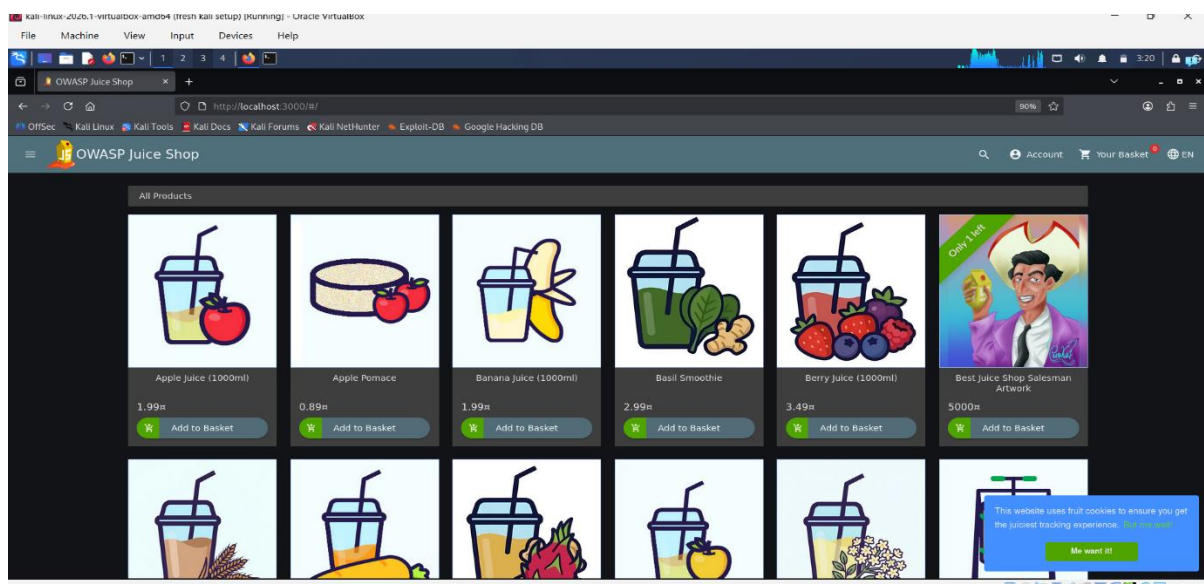


Figure 1: OWASP Juice Shop Application Running Successfully

2. Scope of Assessment

In Scope

- OWASP Juice Shop running locally
- Local lab environment
- Passive and active vulnerability scanning

Out of Scope

- Exploitation attacks
- Denial of Service testing
- Real-world websites
- External systems

3. Tools Used

Tool	Purpose
Nmap	Host discovery and port scanning
Nikto	Web vulnerability scanning
Dirsearch	Hidden directory enumeration
Docker	Hosting OWASP Juice Shop
Kali Linux	Penetration testing platform

4. Methodology

The assessment was conducted in the following phases:

1. Host Discovery
2. Port and Service Enumeration
3. Vulnerability Scanning
4. Hidden Directory Enumeration
5. Evidence Collection
6. Risk Analysis and Remediation

5. Technical Findings

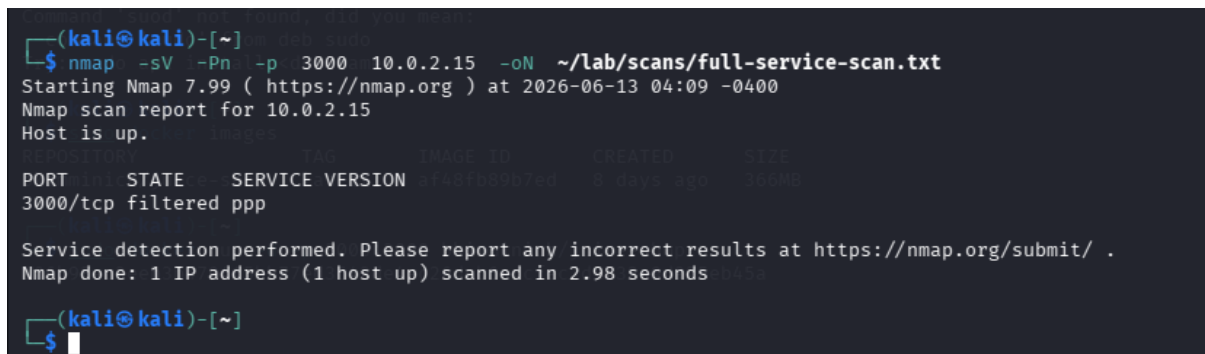
Finding 1: Open Web Service Detected

Tool Used

Nmap

Evidence

Port 3000/tcp was found open and running an HTTP service.



```
(kali㉿kali)-[~]
└─$ nmap -sV -Pn -p 3000 10.0.2.15 -oN ~/lab/scans/full-service-scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-13 04:09 -0400
Nmap scan report for 10.0.2.15
Host is up.

```

PORT	STATE	SERVICE	VERSION	TAG	IMAGE ID	CREATED	SIZE
3000/tcp	filtered	ppp					

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.98 seconds
```

```
(kali㉿kali)-[~]
└─$
```

Figure 2: Nmap Scan Showing Open Port 3000

Risk Rating

Medium

Impact

Attackers may identify exposed services and perform further reconnaissance.

Remediation

Restrict unnecessary service exposure and implement firewall filtering.

Finding 2: Missing Security Headers

Tool Used

Nikto

Evidence

Nikto identified missing security headers including:

- Content-Security-Policy
- X-Content-Type-Options
- Referrer-Policy

```
kali-linux-2026.1-virtualbox-amd64 (fresh kali setup) (Running) - Oracle VM VirtualBox
File Machine View Input Devices Help

Session Actions Edit View Help
Use 'sudo apt autoremove' to remove them.

Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 36

(kali@kali)~$ nikto -u http://localhost:3000
- Nikto v2.6.0

+ Target IP: 127.0.0.1
+ Target Hostname: localhost
+ Target Port: 3000
+ Platform: Unknown
+ Start Time: 2026-06-13 04:18:37 (GMT-4)

+ Server: No banner retrieved
+ ERRORS: failed to check for updates: 403
+ [999986] /: Retrieved access-control-allow-origin header: *.
+ [999100] /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999996] /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [001575] /http/: This might be interesting.
+ [001511] /public/: This might be interesting.
+ [002790] /.htpasswd: Contains authorization information.
+ [002763] /.bash_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ [002756] /.sh_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ [007201] /userdata.json: This might be interesting.
+ [007204] /login.json: This might be interesting.
+ [007205] /master.json: This might be interesting.
+ [007206] /masters.json: This might be interesting.
+ [007207] /connections.json: This might be interesting.
+ [007208] /connection.json: This might be interesting.
+ [007210] /pastpasswords.json: This might be interesting.
+ [007211] /users.json: This might be interesting.
+ [007212] /cmds.json: This might be interesting.
+ [007213] /comm.json: This might be interesting.
+ [007215] /accounts.json: This might be interesting.
+ [007203] /changepass.jsp: JSP - Java Application Monitor Admin interface identified. Versions 2.7 and earlier contain XSS vulnerabilities. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2013-6235
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabili
ties/missing-content-type-header/
+ 0637 requests: 2 errors and 25 items reported on the remote host
+ End Time: 2026-06-13 04:21:46 (GMT-4) (189 seconds)

+ 1 host(s) tested
(kali@kali)~$
```

Figure 3: Nikto Vulnerability Scan Results

Risk Rating

Medium

Impact

Missing headers can increase the risk of clickjacking and content injection attacks.

Remediation

Configure secure HTTP response headers on the web server.

Finding 3: robots.txt Disclosure

Tool Used

Nikto / Dirsearch

Evidence

The robots.txt file was publicly accessible.

Risk Rating

Low

Impact

Sensitive paths may be disclosed to attackers.

Remediation

Avoid exposing sensitive paths through robots.txt.

Finding 4: Interesting JSON Endpoints Identified

Tool Used

Nikto

Evidence

Several JSON endpoints were identified during scanning.

Risk Rating

Medium

Impact

Sensitive API endpoints may expose application information.

Remediation

Apply authentication and input validation controls.

Finding 5: Hidden Directory Enumeration

Tool Used

Dirsearch

Evidence

Dirsearch identified accessible hidden resources including:

- /.well-known/security.txt

```
Kali-linux-2026.1-virtualbox-amd64 (fresh kali setup) [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help
Target: http://localhost:3000/
[05:29:45] Starting:
Cannot connect to: localhost:3000
Task Completed

(kali@kali)-[~]
$ ls ~/lab/scans
full-service-scan.txt  host-discovery.txt  nikto.txt.txt

(kali@kali)-[~]
$ sudo docker start $(sudo docker ps -aq)
a06b93ec3eeb
Error response from daemon: failed to set up container networking: driver failed programming external connectivity on endpoint frosty_h
ailed: port is already allocated
Error: failed to start containers: 37f7c382f231

(kali@kali)-[~]
$ sudo docker ps
CONTAINER ID   IMAGE               COMMAND                  CREATED       STATUS       PORTS
a06b93ec3eeb   bkimminich/juice-shop  "/nodejs/bin/node /j_..."  2 hours ago   Up About a minute   0.0.0.0:3000->3000/tcp, [::]:3000->3000/tcp

(kali@kali)-[~]
$ dirsearch -u http://localhost:3000 -t 5 -o ~/lab/scans/dirsearch.txt
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setupt
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 5 | Wordlist size: 11460
Output File: /home/kali/lab/scans/dirsearch.txt
Target: http://localhost:3000/
[05:36:16] Starting:
[05:36:45] 200 - 475B - /.well-known/security.txt
CTRL+C detected: Pausing threads, please wait ...
^Cc
Task Completed
^C

(kali@kali)-[~]
$ ls ~/lab/scans
dirsearch.txt  full-service-scan.txt  host-discovery.txt  nikto.txt.txt

(kali@kali)-[~]
$
```

Figure 4: Dirsearch Hidden Directory Enumeration

Risk Rating

Low

Impact

Hidden files may reveal useful information to attackers.

Remediation

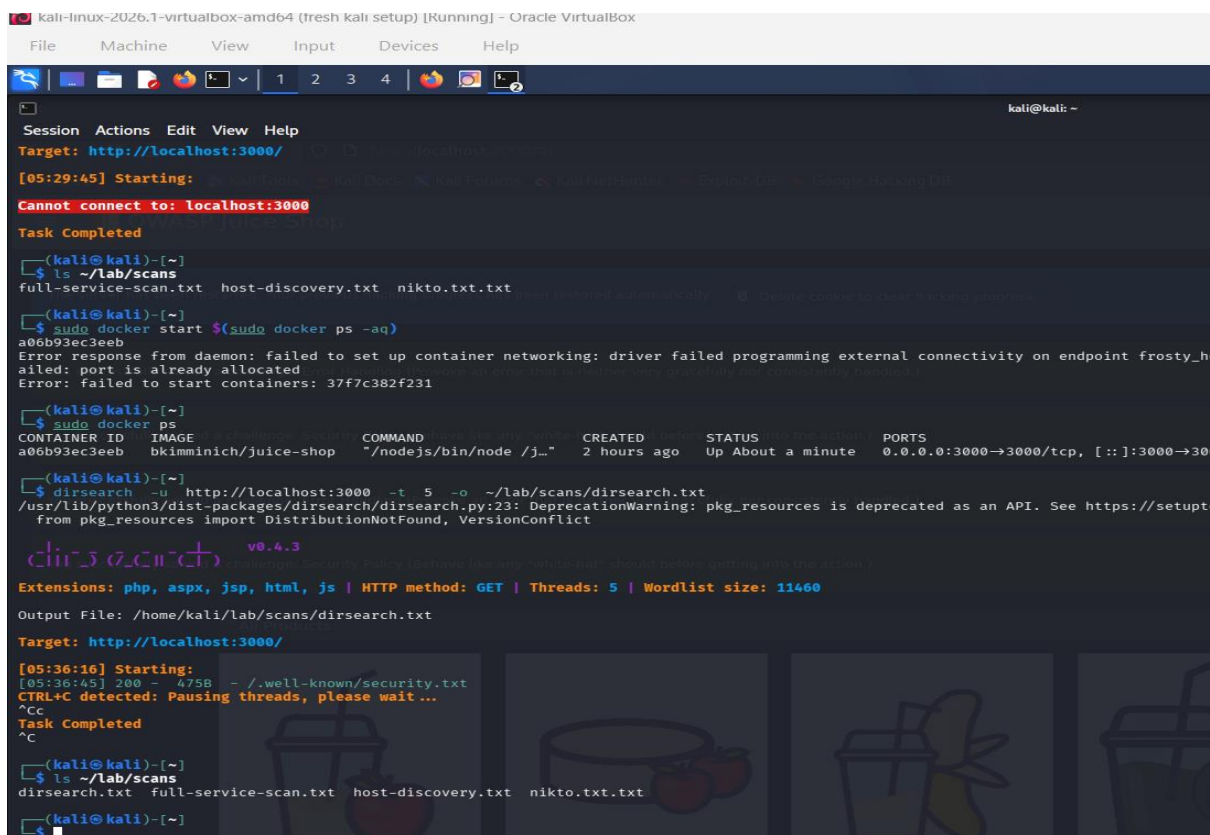
Review publicly accessible files and restrict unnecessary exposure.

6. Evidence Collected

The following evidence files were generated:

- host-discovery.txt
- full-service-scan.txt
- nikto.txt
- dirsearch.txt

Screenshots of scan outputs were also collected.



```
kali-linux-2026.1-virtualbox-amd64 (fresh kali setup) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

kali@kali: ~
Session Actions Edit View Help
Target: http://localhost:3000/
[05:29:45] Starting:
Cannot connect to: localhost:3000
Task Completed

(kali@kali)-[~]
$ ls ~/lab/scans
full-service-scan.txt  host-discovery.txt  nikto.txt.txt

(kali@kali)-[~]
$ sudo docker start $(sudo docker ps -aq)
a06b93ec3eeb
Error response from daemon: failed to set up container networking: driver failed programming external connectivity on endpoint frosty_h
ailed: port is already allocated
Error: failed to start containers: 37f7c382f231

(kali@kali)-[~]
$ sudo docker ps
CONTAINER ID   IMAGE               COMMAND                  CREATED        STATUS      Port
a06b93ec3eeb   bkimminich/juice-shop  "/nodejs/bin/node /j_..."  2 hours ago   Up About a minute   0.0.0.0:3000->3000/tcp, [::]:3000->3000/tcp

(kali@kali)-[~]
$ dirsearch -u http://localhost:3000 -t 5 -o ~/lab/scans/dirsearch.txt
/usr/lib/python3/dist-packages/dirsearch/py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setupt
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 5 | Wordlist size: 11460
Output File: /home/kali/lab/scans/dirsearch.txt
Target: http://localhost:3000/
[05:36:16] Starting:
[05:36:45] 200 - 475B - /_well-known/security.txt
CTRL+C detected: Pausing threads, please wait...
^C
Task Completed
^C

(kali@kali)-[~]
$ ls ~/lab/scans
dirsearch.txt  full-service-scan.txt  host-discovery.txt  nikto.txt.txt

(kali@kali)-[~]
$
```

Figure 5: Evidence Files Generated During Assessment

7. Conclusion

The Vulnerability Assessment successfully identified multiple security weaknesses within the OWASP Juice Shop application hosted in a controlled lab environment. The assessment demonstrated how cybersecurity analysts use reconnaissance and vulnerability scanning tools to identify exposed services and web security misconfigurations. This task provided practical experience in vulnerability assessment methodology, evidence collection, and professional security reporting.

8. References

1. OWASP Vulnerability Assessment Project

<https://owasp.org/www-project-vulnerability-assessment/>

2. Nmap Official Documentation

<https://nmap.org/docs.html>

3. Nikto Web Scanner Documentation

<https://github.com/sullo/nikto>

4. Dirsearch GitHub Repository

<https://github.com/maurosoria/dirsearch>

5. OWASP Juice Shop Project

<https://owasp.org/www-project-juice-shop/>